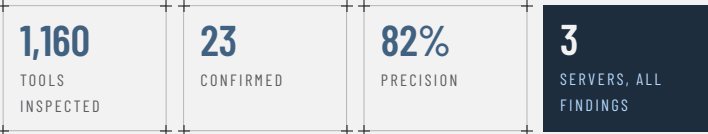


DON'T TRUST MCP HINT DECLARATIONS. VERIFY THEM.

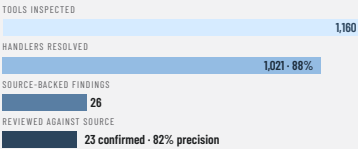
If your platform gates destructive actions on MCP annotations, it trusts a declaration no one verifies. We scanned 20 public servers and confirmed 23 mismatches — **20 of them tools that delete cloud resources while declaring nothing**, each one a policy engine would wave through.

MOST DANGEROUS FINDING

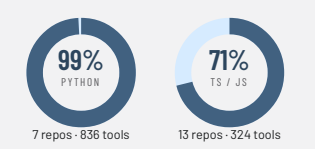
One tool builds an outbound URL from tool input with no allowlist, reaching `fetch()`: a prompt injection turns it into SSRF from your own network. **No hint value would have stopped it — hint hygiene is the floor, not the ceiling.**



WHAT A SCAN ACTUALLY REACHES



COVERAGE DEPENDS ON THE STACK



Where the pale bar runs past the solid one, a tool was seen but its handler never resolved. **Those 139 tools are unchecked, not clean.**

KNOWN COVERAGE GAPS — READ THESE AS UNCHECKED

- + Dynamically loaded tools — need runtime tools/list introspection
- + Imported tool arrays — cross-file resolution incomplete
- + Go, Rust, Java, C# — no extractor support yet